



Testing Plan NEMU IPB

Perancangan dan Implementasi Protokol Keamanan Informasi pada Sistem NEMU IPB

Kelompok 7

Salma Putri Hanifah	G6401231010
Marsya Hasna Khairunnisa	G6401231015
Lathiifa Zahira Yahya	G6401231154

1. Pendahuluan

Testing plan ini digunakan untuk menguji aspek keamanan informasi pada NEMU IPB, khususnya protokol AAA, yaitu *Authentication*, *Authorization*, dan *Accounting*. Pengujian juga mencakup validasi token/session, *password hashing*, *input validation*, keamanan API, keamanan proses verifikasi laporan/klaim/drop off, notifikasi, *digital signature*, integritas dokumen serah terima, dan konsistensi database.

Pengujian dilakukan untuk memastikan fitur berhasil digunakan, memastikan sistem menolak akses tidak sah, melindungi data sensitif, mencatat aktivitas penting, dan mendeteksi manipulasi data.

2. Ruang Lingkup Pengujian

Ruang lingkup pengujian meliputi:

1. Authentication
2. Authorization
3. Accounting / Activity Log
4. Session/token validation
5. Password hashing
6. Input validation
7. API security
8. Report verification security
9. Claim/dropoff verification security
10. Notification security
11. Digital signature dan document integrity

12. Database integrity

3. Strategi Pengujian

Strategi	Penjelasan
Positive test	Menguji alur valid, misalnya login benar, admin menyetujui laporan, atau signature valid.
Negative test	Menguji input salah, token invalid, password salah, atau akses tanpa hak.
Security abuse case	Menguji skenario penyalahgunaan, seperti civitas mengakses endpoint admin atau manipulasi dokumen serah terima.
Role-based test	Menguji perbedaan akses antara role civitas dan admin.
API-level test	Menguji endpoint langsung melalui Postman/Thunder Client tanpa bergantung pada frontend.
Data integrity test	Menguji apakah database tetap konsisten setelah transaksi berhasil atau gagal validasi.

4. Environment Pengujian

Komponen	Keterangan
Local development	Pengujian dilakukan pada environment lokal sebelum deployment.
Backend FastAPI	Menjalankan API, validasi token, service layer, dan business logic.
Frontend React	Digunakan untuk uji alur pengguna pada tampilan.
PostgreSQL	Database utama untuk memeriksa data user, laporan, barang, klaim, notifikasi, serah terima, dan activity log.

5. Test Case Keamanan

ID	Area Keamanan	Tujuan	Precondition	Langkah Pengujian	Data Uji	Expected Result	Status
SEC-AUTH-01	Authentication	Memastikan login valid menghasilkan token	User aktif tersedia	Login melalui frontend	Username valid, password valid	Login berhasil, response berisi access token dan data user	Berhasil
SEC-AUTH-02		Memastikan password salah ditolak	User terdaftar	Login dengan password salah	Username valid, password salah	Muncul pesan password salah	Berhasil
SEC-AUTH-03		Memastikan email tidak terdaftar ditolak	Tidak ada user terkait	Login dengan username tidak terdaftar	Username tidak valid	Muncul pesan user tidak ditemukan	Berhasil
SEC-HASH-01	Password Hashing	Memastikan password tidak tersimpan plaintext	Database dapat diperiksa	Cek kolom password di tabel users	Data user existing	Database menyimpan password_hash, bukan password plaintext	Berhasil
SEC-AUTHZ-01	Authorization	Civitas tidak boleh akses dashboard admin	Login sebagai civitas	Akses endpoint/dashboard admin	Token civitas	UI menolak akses dan tidak ada tampilan dashboard admin	Berhasil
SEC-AUTHZ-02		Civitas tidak boleh menyutujui/menolak	Login sebagai civitas	Panggil endpoint verifikasi laporan	Token civitas, laporan_id valid	Tidak ada menu verifikasi laporan dan status laporan	Berhasil

		laporan				tidak berubah	
SEC-A UTHZ-03		Civitas tidak boleh verifikasi klaim/dropoff	Login sebagai civitas	Panggil endpoint verifikasi klaim/pick up/dropoff	Token civitas	Tidak menampilkan menu verifikasi klaim/drop off Data tidak berubah	Berhasil
SEC-A UTHZ-04		Admin dapat mengakses fitur verifikasi	Login sebagai admin	Akses halaman/endpoint verifikasi	Token admin	Request diterima sesuai aturan validasi	Berhasil
SEC-A UTHZ-05		User hanya melihat laporan miliknya jika fitur dibatasi	Login sebagai civitas	Akses daftar laporan milik sendiri	Token civitas	Endpoint /laporan/me hanya mengembalikan laporan user tersebut	Berhasil
SEC-T OKEN-01	Token/Session	Endpoint protected menolak request tanpa token	Endpoint protected tersedia	Panggil endpoint tanpa Authorization header	Tidak ada token	Response 401/403, data tidak dikirim	Berhasil
SEC-T OKEN-02		Token invalid ditolak	Endpoint protected tersedia	Panggil endpoint dengan bearer token palsu	Token invalid	request ditolak	Berhasil
SEC-T OKEN-03		Token setelah logout tidak dapat dipakai kembali dari	User sudah logout	Coba akses fitur protected dari UI	Token sudah dihapus client	UI meminta login ulang	Berhasil

		frontend					
SEC-TOKEN-04		Memastikan session aktif tercatat	Migration sessions tersedia	Cek apakah login membuat record session	User valid	Session tercatat	Berhasil;
SEC-TOKEN-05		Memastikan logout menonaktifkan akses dari sisi client	User sudah login	Logout, lalu akses fitur protected dari frontend	Token sebelumnya	Token di localStorage terhapus; akses frontend protected meminta login ulang	Berhasil
SEC-INPUT-01	Input Validation	Laporan kehilangan dengan field kosong ditolak	Login sebagai civitas	Submit laporan kehilangan dengan field wajib kosong	nama_barang kosong	Response validasi error, muncul UI pesan wajib diisi	Berhasil
SEC-INPUT-02		Laporan penemuan dengan field kosong ditolak	Login sebagai civitas	Submit laporan penemuan dengan field wajib kosong	lokasi kosong	Response validasi error, muncul UI pesan wajib diisi	Berhasil
SEC-REPORT-01	Report Verification	Admin menyetujui laporan valid	Login admin, laporan menunggu	Setujui laporan	laporan_id valid	Status laporan berubah, notifikasi dibuat	Berhasil
SEC-REPORT-02		Admin menolak laporan dengan catatan	Login admin, laporan menunggu	Menolak laporan dengan catatan	Catatan admin	Status ditolak, catatan tersimpan, notifikasi dibuat	Berhasil

SEC-REPOR T-03		Civitas tidak dapat mengubah status verifikasi sendiri	Login civitas	Panggil endpoint verifikasi laporan	Token civitas	Sistem hanya menampilkan status laporannya	Berhasil
SEC-REPOR T-04	Notification	Perubahan status laporan menghasilkan notifikasi	Laporan diverifikasi admin	Cek tabel/endpoint notifikasi user	Setujui/menolak laporan	Notifikasi baru muncul untuk pemilik laporan	Berhasil
SEC-CLAIM-01	Claim Security	Klaim hanya memakai laporan kehilangan valid	Login civitas	Klaim barang dengan laporan kehilangan sendiri	laporan_kehilangan_id valid	Klaim dibuat dengan status diproses	Berhasil
SEC-CLAIM-02		Klaim ganda ditolak jika aturan pembatasan	Klaim aktif sudah ada	Ajukan klaim kedua untuk barang/laporan sama	barang_id sama	Response error, tidak ada klaim duplikat aktif	Berhasil
SEC-CLAIM-03		Admin setuju klaim valid	Login admin, klaim diproses	Verifikasi klaim diterima	status diterima	Status klaim diterima, barang diklaim, dokumen serah terima dibuat	Berhasil
SEC-CLAIM-04		Admin tolak klaim tidak valid	Login admin, klaim diproses	Verifikasi klaim ditolak	status ditolak	Status klaim ditolak, notifikasi dikirim	Berhasil

SEC-D ROPO FF-01	Dropoff Security	Dropoff hanya untuk laporan penemua n valid	Laporan penemua n disetujui dan kode drop off terkirim	Verifikasi kode dropoff	Kode dropoff valid	Status laporan/bar ang diperbarui sesuai aturan	Berhasil
SEC-D ROPO FF-02		Verifikas i dropoff memper barui status barang/la poran	Login admin	Masukkan kode dropoff valid	Kode dropoff valid	Status laporan selesai dan barang tersedia ditemukan	Berhasil
SEC-D ROPO FF-03		Verifikas i dropoff tercatat di activity log	Login admin	Verifikasi dropoff lalu cek log	Kode dropoff valid	Activity log berisi aksi returned/dr opoff	Berhasil
SEC-SI GN-01	Digital Signature	Sistem menghas ilkan dokumen serah terima setelah proses valid	Klaim valid diterima admin	Cek data serah terima	klaim_id valid	Record serah terima dibuat	Berhasil
SEC-SI GN-02		Sistem menghas ilkan digital_si gnature	Dokume n serah terima ada	Ambil detail serah terima	klaim_id valid	Response memiliki digital_sig nature	Berhasil
SEC-SI GN-03		Verifikas i signature berhasil untuk dokumen asli	Dokume n serah terima asli ada	Panggil endpoint verify	klaim_id valid	valid=true, hash dan signature valid	Berhasil

SEC-SIGN-04		Public key tersedia untuk verifikasi	Dokumen serah terima ada	Ambil detail serah terima	klaim_id valid	Response memiliki public_key	Berhasil
SEC-INT-01	Document Integrity	Verifikasi gagal jika dokumen dimanipulasi	Salinan data uji tersedia	Ubah isi dokumen pada data uji lalu verifikasi	Dokumen termodifikasi	Hash/signature tidak valid	Berhasil
SEC-SIGN-02		Sistem menghasilkan dokumen_hash	Dokumen serah terima ada	Ambil detail serah terima	klaim_id valid	Response memiliki dokumen_hash	Berhasil
SEC-LOG-01	Accounting	Aksi setuju/tolak laporan masuk activity log	Login admin	Setujui/tolak laporan	laporan_id valid	Log baru tercatat	Berhasil
SEC-LOG-02		Aksi verifikasi klaim masuk activity log	Login admin	Setujui klaim lalu cek log	klaim_id valid	Log klaim dapat dilihat	Berhasil
SEC-LOG-03		Aksi verifikasi dropoff masuk activity log	Login admin	Verifikasi dropoff lalu cek log	kode dropoff valid	Log verifikasi tercatat	Berhasil
SEC-LOG-05		Log dapat dilihat/di filter admin jika fitur tersedia	Login admin	Akses /admin/logs dengan filter	action_type, sort_by	Admin menerima daftar log sesuai filter	Berhasil

SEC-A PI-01	API Security	Endpoint protected tidak bisa diakses tanpa autentika si	Endpoint protected tersedia	Request tanpa token	Tidak ada token	Response 401/403	Berhasil
SEC-A PI-02		Endpoint admin tidak bisa diakses civitas	Login civitas	Request endpoint admin	Token civitas	Response 403	Berhasil

6. Traceability ke Fitur Sistem

Fitur	Area keamanan	ID test case terkait
Login	Authentication, password hashing, token	SEC-AUTH-01, SEC-AUTH-02, SEC-AUTH-03, SEC-HASH-01
Logout	Token/session	SEC-TOKEN-03, SEC-TOKEN-05
Endpoint protected	Token validation, API security	SEC-TOKEN-01, SEC-TOKEN-02, SEC-API-01
Dashboard dan fitur admin	Authorization, RBAC	SEC-AUTHZ-01, SEC-AUTHZ-04, SEC-API-02
Pembuatan laporan	Input validation	SEC-INPUT-01, SEC-INPUT-02
Verifikasi laporan	Authorization, notification, accounting	SEC-AUTHZ-02, SEC-REPORT-01, SEC-REPORT-02, SEC-REPORT-03, SEC-REPORT-04, SEC-LOG-01

Klaim barang	Claim security, authorization	SEC-CLAIM-01, SEC-CLAIM-02, SEC-CLAIM-03, SEC-CLAIM-04
Dropoff barang	Dropoff security, accounting	SEC-DROPOFF-01, SEC-DROPOFF-02, SEC-DROPOFF-03, SEC-LOG-03
Dokumen serah terima	Digital signature, document integrity	SEC-SIGN-01, SEC-SIGN-02, SEC-SIGN-03, SEC-SIGN-04, SEC-INT-01
Activity log	Accounting, audit trail	SEC-LOG-01, SEC-LOG-02, SEC-LOG-03, SEC-LOG-05
Notifikasi	Notification security	SEC-REPORT-04, SEC-CLAIM-04

7. Kriteria Keberhasilan

Pengujian dicantumkan status berhasil apabila:

1. Semua endpoint protected menolak akses tanpa token atau dengan token invalid.
2. Password tidak tersimpan dalam bentuk plaintext di database.
3. Role admin dan civitas berjalan sesuai batasan akses.
4. Civitas tidak dapat menjalankan aksi admin seperti setuju/tolak laporan dan verifikasi klaim/drop off.
5. Activity log mencatat aksi penting yang dilakukan admin atau sistem.
6. Digital signature dan document hash dapat mendeteksi manipulasi dokumen serah terima.
7. Notifikasi terkirim saat status laporan, klaim, atau dropoff berubah.
8. Database tetap konsisten setelah transaksi berhasil atau gagal validasi.